

08 Source Analysis

Jonathan Knudsen

jonathan.knudsen@duke.edu

Fall 2019

The goal of this assignment is to perform a source analysis of the Jitsi project, and to answer some questions about source analysis and the results you have generated.

Install and Run SonarQube

You can do this assignment wherever you wish. However, using your Duke virtual machine is probably the simplest option and is how I will describe the steps.

Start at <https://vcm.duke.edu> and reserve an Ubuntu 18 machine if you haven't already done so. Make sure it's started up and then ssh to it.

Get SonarQube for Linux:

```
wget https://binaries.sonarsource.com/Distribution/sonarqube/sonarqube-8.0.zip
```

Unzip it. SonarQube runs on Java so you'll need to get OpenJDK:

```
sudo apt install -y openjdk-11-jdk
```

Now go to the directory where you unzipped SonarQube. Use the following command to run it:

```
bin/linux-x86-64/sonar.sh start
```

After a minute or two, see if you can access SonarQube from a browser. Use the name of your virtual machine. For me, it is this:

<http://vcm-11091.vm.duke.edu:9000/>

If SonarQube won't start, try running the following to get an informative error message:

```
bin/linux-x86-64/sonar.sh console
```

Once you can see SonarQube in your browser, log in with admin/admin, then immediately change your password. Click on **A** in the top right corner, then choose **My Account**, then **Security**.

Build Jitsi

The next step is building the Jitsi project. Jitsi is a softphone implemented as a Java desktop application.

Normally you would do the build and analysis of Jitsi on a different machine, but to keep things simpler for this assignment, you'll do the build and analysis on the same Duke VM where you are running SonarQube.

Get the source code like this:

```
git clone https://github.com/jitsi/jitsi.git
```

To build Jitsi, you'll need the Oracle JDK 8. You will have to create a free Oracle account in order to download it. Start here:

<https://www.oracle.com/technetwork/java/javase/downloads/jdk8-downloads-2133151.html>

The file you want is *jdk-8u231-linux-x64.tar.gz*. You might end up downloading it to your laptop, then using `scp` to get it to your VM.

Unpack the Oracle JDK file:

```
tar zxvf jdk-8u231-linux-x64.tar.gz
```

Now to build Jitsi, you'll temporarily adjust the `PATH` environment variable so that the Oracle JDK 8 is used instead of the OpenJDK 11 we installed earlier. I unpacked the Oracle JDK into an *Applications* folder, so for me, it looks like this (the `~` is my home directory):

```
export PATH=~/.Applications/jdk1.8.0_231/bin:$PATH
```

You can verify it by checking the version of `javac`:

```
$ javac -version
javac 1.8.0_231
```

You will also need the `ant` build tool:

```
sudo apt install -y ant
```

Now you should be ready to build. Go to the *jitsi* directory and try this:

```
ant rebuild
```

After 20-30 seconds, you should see a **BUILD SUCCESSFUL** message.

Analyze Jitsi with SonarScanner for Ant

Because Jitsi uses the `ant` build system, use the following:

<https://docs.sonarqube.org/latest/analysis/scan/sonarscanner-for-ant/>

Download the file to your VM:

```
wget  
https://binaries.sonarsource.com/Distribution/sonarqube-ant-task/sonarqube-ant-  
task-2.7.0.1612.jar
```

Now, follow the instructions on the SonarScanner for Ant web page to update the `ant` build file, which is *build.xml*. Some of it is copying and pasting, but pay attention and change what needs changing.

1. Add the `xmlns` clause (from the Sonar page) to the top-level `<project>` element in *build.xml*.
2. Add the `sonar.host.url` property by copying and pasting. Adjust if necessary. In a more normal installation, the Sonar server would run on one machine, and the build and analysis would happen somewhere else.
3. Add the other properties and adjust as needed. In particular, you must change `sonar.java.binaries` to correspond to the Jitsi project. The binaries for Jitsi are stored in *sc-bundles*.
4. Finally, add the `sonar <target>`. You can copy and paste, but then make sure to adjust the classpath to point to the exact path and filename for the SonarScanner for Ant file that you downloaded earlier.

Attempt to analyze the source code:

```
ant sonar
```

If you get an error, you probably have a problem in *build.xml* you need to fix.

If it works, it will take a few minutes (7.5 minutes on my last run) until the analysis is done, then a little more time before you can see the results in SonarQube in your browser.

Submission

Submit the following and answer the questions:

1. Make a screen shot of your browser, showing the SonarQube results for Jitsi.
2. SonarQube reports on four types of issues. Describe each one in your own words.
3. Which issue type do you believe is most important? Why?
4. Look at the list of vulnerability issues. Choose five that are each triggered by a different rule. For each one, show a screen shot and explain what you believe should happen with the issue. Would you follow SonarQube's advice? Would you take some other action? Is the issue a false positive?
5. Find the "Sonar way" quality gate. Describe what it means in your own words. Does it seem like a good policy? Would you add or remove anything? Would it make a difference if you were making software for a smart light bulb or a nuclear submarine?